

Aide-mémoire par type de challenge. Sur Kali, la plupart de ces outils sont déjà préinstallés — sinon la commande d'install est indiquée.

Réflexe de départ sur chaque fichier inconnu :

```
file mystere           # identifie le vrai type (l'extension ment souvent)
strings mystere        # extrait les chaines lisibles – le flag y est parfois en clair
strings -n 8 mystere   # filtre les chaines d'au moins 8 caractères
xxd mystere | less     # dump hexa, pour repérer les magic bytes / structure
```

Le flag picoCTF a toujours la forme `picoCTF{...}` → un `strings fichier | grep -i pico` fait gagner un temps fou.

Crypto

Situation	Outil / méthode
ROT13, César, base64, XOR, hex, morse...	CyberChef (web, aucun install) — la référence absolue
Vigenère, substitution	dcode.fr, ou scripts Python
RSA (n, e, c donnés)	RsaCtfTool, pycryptodome
Identifier un chiffrement inconnu	dcode.fr "cipher identifier"
Manipulation crypto en Python	pip install pycryptodome

```
# Bookmarker : https://gchq.github.io/CyberChef/
pip install pycryptodome
git clone https://github.com/RsaCtfTool/RsaCtfTool.git
```

90% des challenges crypto picoCTF se résolvent dans CyberChef. Commence toujours par là.

Forensics / Stéganographie

Situation	Outil
Fichiers cachés DANS un fichier	binwalk -e fichier (extraction)
Récupérer des données effacées	foremost , photorec
Données cachées dans une image	steghide extract -sf img.jpg , zsteg , stegsolve
Métadonnées (EXIF, auteur, GPS...)	exiftool fichier
Analyse d'un pcap (réseau)	Wireshark, tcpdump
Dump mémoire (RAM)	volatility3
Corbeille Windows (\$!/\$R)	rifiuti2

```
sudo apt install binwalk foremost steghide exiftool
# zsteg (PNG/BMP) :
sudo gem install zsteg
# stegsolve : télécharger le .jar (couteau suisse stégano image)
```

Ordre de réflexe sur une image suspecte : `exiftool` → `binwalk` → `steghide` / `zsteg` → `stegsolve` (jouer sur les plans de bits).

Web

Situation	Outil
Interceptor / modifier des requêtes	Burp Suite (préinstallé, Community)
Découvrir répertoires / fichiers cachés	gobuster , ffuf , dirsearch
Injection SQL	sqlmap
Scan de vulnérabilités web	nikto
Inspecter cookies / JS / requêtes	DevTools du navigateur (F12)
Décoder un JWT	jwt.io, ou CyberChef

```
sudo apt install gobuster ffuf sqlmap nikto
```

Réflexes web à toujours vérifier : le code source de la page (Ctrl+U), les commentaires HTML, les cookies, `robots.txt` , `/admin` , les en-têtes HTTP. Beaucoup de flags picoCTF sont planqués là avant même de sortir un outil.

Reverse Engineering

Situation	Outil
Décompiler un binaire (voir le "code source")	Ghidra (gratuit, NSA)
Désassembler / analyser	<code>radare2</code> , <code>objdump -d</code>
Voir les chaînes / la structure	<code>strings</code> , <code>file</code> , <code>nm</code>
Exécuter pas à pas (debug)	<code>gdb</code> + <code>gef</code>
Analyser un .NET / Java	<code>dnSpy</code> , <code>jd-gui</code>

```
sudo apt install gdb radare2 ghidra
# gef (surcouche gdb) :
bash -c "$(curl -fsSL https://gef.blah.cat/sh)"
```

🔗 Sur un binaire "reverse" : commence toujours par `strings` et `file` . Le flag est parfois écrit en dur dans le binaire. Sinon → Ghidra pour lire la logique.

🔧 Binary Exploitation (pwn)

Situation	Outil
Scripter l'exploitation	pwntools (la bibliothèque indispensable)
Vérifier les protections du binaire	<code>checksec</code> <code>fichier</code>
Debug avec vue exploitation	<code>gdb</code> + <code>gef</code> / <code>pwndbg</code>
Calculer des offsets (buffer overflow)	<code>cyclic</code> (fourni avec pwntools)
Trouver des gadgets ROP	<code>ROPgadget</code> , <code>ropper</code>

```
pip install pwntools
sudo apt install checksec
pip install ROPgadget
```

🔗 C'est la catégorie la plus technique. Squelette d'un script pwntools :

```
from pwn import *
p = process('./binaire')      # ou remote('host', port) pour picoCTF
# ... construction du payload ...
p.sendline(payload)
p.interactive()
```

📦 Général / à avoir toujours

```
sudo apt install nmap wireshark netcat-traditional python3-pip git
```

- **nmap** — scan réseau/ports (`nmap -sV -sC cible`)
- **netcat (nc)** — se connecter à un service distant (`nc host port`)
- **Python 3** — le langage de scripting du CTF, incontournable
- **git** — pour cloner les outils qui ne sont pas dans apt

📌 Rappels perso

- **Cracking de hash / mots de passe** (john, hashcat) : à faire sur **Windows avec la RTX 5070**, pas dans la VM (pas de passthrough GPU sous VMware Workstation → CPU only, très lent). Tu récupères le hash dans Kali, tu casses sur l'hôte.
- **Mettre Kali à jour régulièrement** : `sudo apt update && sudo apt full-upgrade -y`
- **N'installe pas tout d'un coup** : installe l'outil quand un challenge en a besoin. Tu apprends chaque outil dans son contexte et la VM reste légère.
- **Le flag est de la forme** `picoCTF{...}` → pense au `grep -i pico` .

🔗 Ressources en ligne (aucun install)

Outil	Usage	URL
CyberChef	Crypto / encodages	gchq.github.io/CyberChef
dcode.fr	Identifier + casser des chiffrements	dcode.fr
CrackStation	Hash → mot de passe (base de données)	crackstation.net
jwt.io	Décoder / forger des JWT	jwt.io
GTFOBins	Escalade de privilèges Linux	gtfobins.github.io

Bon courage sur picoCTF ! 🍀 — commence par les catégories que tu connais déjà (crypto, forensics, web), garde le pwn pour quand tu seras à l'aise avec le reste.